



Kethora Blueprint v1.0 — Build-Ready Review & Remediation Plan

Companion to the Kethora blueprints v1.0 and v1.1 (24 September 2026). Includes reconciliation and build-sufficiency verification addenda against v1.1, with two accepted qualifications to this review.

ADDENDUM — RECONCILIATION AGAINST BLUEPRINT v1.1 (24 September 2026)

Status: v1.1 is now the authoritative build specification. It adopts this review's recommended structure: decision register D01–D08 with owner roles and gates, 26 coverage rows C01–C26, eval suite E01–E04, a per-provider calendar contract with write-identity rules, a dated M0 milestone (22 October 2026), and a G5 outcome measure with a fixed denominator. G0 contract work may begin from v1.1.

Two qualifications to this review, accepted:

1. CalDAV characterization. This review called Google's CalDAV endpoint a "maintenance backwater" and implied abandonment from the May 2026 quota changes. Correction: Google documents quota changes for its CalDAV interface, but those changes alone do not establish that the interface is being abandoned. The substantive recommendation stands — v1.1 D01 uses native adapters for Google Calendar and Microsoft Graph, with CalDAV only for capability-tested server classes — but the abandonment inference is withdrawn.

2. Article 50. This review presented AI-interaction disclosure and synthetic-output marking as firm obligations. Correction: v1.1 treats initiating-account identification as a product transparency choice (§3, D06) and assigns Article 50 applicability, exceptions, and PDF marking implementation to the legal workstream for review before G5. This review's legal assertions are downgraded to "counsel to confirm."

Gap disposition (review IDs → v1.1), all closed at spec level unless noted:

D-01 through D-08 are adopted as v1.1 decisions D01–D08 with owner roles and gate evidence.

G-01 → D01 plus §10 per-provider write identities (Google client event ID, Graph transactionId, CalDAV conditional PUT), the capability matrix table, and test A14x.

G-02 → §12 model-quality gate: versioned golden set of ≥50 tasks, zero fabricated source locators, zero false verified labels, ≥90% agreement with adjudicated human support labels, ≥0.80 macro-F1 across support labels, usefulness rating by two independent reviewers, regression threshold on the frozen set; tests E01–E04.

G-03 → §12: a separate, budgeted different-model support-judgment call emitting schema-validated judgment events, calibration against human adjudication, and user-visible human review for ambiguous or disputed material claims.

G-04 → D05 plus §16: named incident primary and backup before G2, staged wrong-action drill, dual-control audited break-glass.

G-05 → §8, §10, §16: a separate upfront safety reserve for verification/reconciliation that continues past the ordinary task ceiling or deadline; test A16.

G-06 → §13: per-edition cost ceiling plus a shared daily background budget, partial_budget marking with omitted content; row C21.

G-07 → D06 plus §3 and §24; legal review completes at G5.

G-08 → §23: M0 target 22 October 2026 and G1 planning target 5 November 2026.

G-09 → §2 expiring-soon nudge at five minutes; §3 expired-card explanation with one-tap re-request from the current immutable payload; test U15.

G-10 → §15 recovery ceremony: unused recovery code plus verified-email challenge, atomic code consumption, session and grant rotation, 24-hour risk hold on external writes/reset/export; test S07.

G-11 → §7: retain idempotency keys through the maximum task deadline plus reconciliation interval, minimum 30-day window.

G-12 → §2: hosts synchronize clocks; the gateway refuses a new claim when measured skew exceeds two seconds or cannot be checked.

G-13 → D04 plus §5: PostgreSQL full-text retrieval owned by memory/artifact at G1; vector search only in-database after explicit consent at G3.

G-14 → §14: transactional notification outbox with deterministic intent keys per recipient/channel, honest channel statuses; test P10.

G-15 → §14: optional one-tap "Was this right?" feedback and a product-quality dashboard by task class and route; rows C22, test E04.

G-16 → D03 plus §19: Temporal Worker Deployment Versioning with pinned versions and Continue-as-New boundaries; N → N+1 fault test A21.

G-17 → §4 credential-flow paragraph plus the §22 credential table (issuer, recipient, lifecycle, revocation per credential).

G-18 → §7 and §8: processor outage means waiting(provider) with no premature publication; exactly one counted schema repair then a defined wait/failure; tests A17–A18.

G-19 → §14: tombstones active at least 35 days and longer than the oldest restorable backup plus margin; restore replays tombstones before activation.

G-20 → §12: tagged PDF must pass a PDF/UA conformance checker plus a human screen-reader check; tests A12–A13.

G-21 → row C23.

G-22 → §10 capability matrix plus §18: a separately authorized live test account for each enabled provider/server class; test A14x.

G-23 → §20 G5 outcome measure: 14 consecutive days, ≥50 eligible tasks from ≥25 accounts, ≥95% verified-success, fixed-at-admission denominator, zero hard blockers.

G-24 → §9: the approval card states the calendar service may send invitations; v1 is one-off events only.

G-25 → §8: every inference call counts against the twelve-turn limit, including child, schema-repair, and judgment calls; the client displays turns used.

G-26 → §7: the 429 shape is specified (code, operation, retry_after_seconds, limit_scope, request_id, Retry-After header).

G-27 → §14: optional per-task diagnostic capture needs affirmative consent, samples at most 5%, expires after 30 days, excludes credentials, logs every access.

G-28 → §9: policy versions are validated against fixtures and canaried; a loosening policy never grants an existing task additional access.

G-29 → §15: iOS Keychain after-first-unlock this-device-only class, tiered file protection, token-based APNs auth, trusted approval origin, single-use invites with App Attest plus accessible fallback.

G-30 → §5 and §12: claim-to-source-version-to-artifact-version lineage edge table driving targeted invalidation; journeys J1/J3.

G-31 → §13: seven-day notice before monitor write-authority expiry, renewal by fresh authenticated grant, never auto-renewed; test P11.

G-32 → §14: the v1 export format is stated as not importable.

G-33 → §15: tests S07b (malicious structured model output), S08 (forged provider endpoint), S09 (email approval phishing).

G-34 → §6: at deadline, stop new claims, expire unclaimed permits/approvals, reconcile claimed effects; terminal expired only after a recorded outcome; test A19.

G-35 → D08 plus §16: two zones cover a zone fault, not a region fault; region recovery is backup restore with dispatch disabled during reconciliation.

Partially adopted: D-09 (per-agent Linux VM). v1.1 §4 and §11 specify disposable microVMs with no credential route for untrusted code execution. The broader intention in section 8 of this review — each acting agent gets its own Linux computer as a general compute layer — is not stated in v1.1. Section 8 is retained as a proposed refinement for the G0 decision record.

Remaining open — explicit gate inputs, not asserted as done: the production model route and version pins (G0); live calendar capability results per provider/server class (G2); named incident primary and backup (G2).

Updated build stance: G0 contract work can begin from v1.1. No user data reaches an unnamed processor; no external write ships until a tested account class, owner, and response runbook are ready. This review's remaining value is as the verification checklist behind v1.1's gates: every item marked "closed at spec level" above still needs its named evidence — commit, environment, test ID, live or fixture mode — before it counts as built.

ADDENDUM 2 — BUILD-SUFFICIENCY VERIFICATION (24 September 2026)

Method. Full-text inspection of Kethora_Personal_Agent_Blueprint_v1.1.txt (110,942 characters). Zero TBD/TODO markers in the entire document. All 35 gap dispositions (G-01–G-35) and every section citation in Addendum 1 were re-verified against the source text. Contradiction scan across gates, decisions D01–D08, coverage rows C01–C26, and the A/M/P/S/U/E test suites. PDF integrity check passed (tagged PDF, addendum present).

Verdict. The specification is sufficient as a gated construction specification: an autonomous builder can execute gates G0 through G4 on deterministic fixtures and synthetic accounts, and stage G5. It is not a zero-design codegen prompt — G0 is contract-definition work by design, with explicit exit evidence.

What the specification supplies. Named decisions D01–D08 with owner roles, gates, and required evidence. Fully narrated critical journeys J1, J2, J3. Coverage rows C01–C26 mapping product behaviors to backend owners, test IDs, target platforms, and gates. A/M/P/S/U/E test suites with concrete scenarios and required observations. Repository layout, clean-checkout contract, staging and production deployment procedures, the §22 credential lifecycle table, the deployable unit inventory, and per-gate exit evidence.

Defined by the builder at G0 (exit criteria cover each item). API route inventory and versioned OpenAPI schema — the task contract and event envelope shapes are specified; the endpoint list is G0 work product. Database DDL — tables are named conceptually (command/event/outbox/invoice records, lineage edge table); migrations are forward-only. Temporal workflow name inventory. Feature-manifest and test-receipt formats. SwiftUI versus UIKit. Email delivery provider (in-product inbox suffices until G4).

Human-only inputs (explicitly gated, none hidden). Production processor and model IDs, data-processing agreement, no-training-use terms, and consent UX (G0/D02). Authorizing live OAuth test accounts for each enabled provider and server class (G2/D01). Named incident primary and backup plus runbook (G2/D05). Legal review including Article 50 applicability, Terms and Privacy, and launch geography (G5/D06). The invited alpha cohort for the G5 outcome measure: 14 consecutive days, at least 50 eligible admitted read-to-brief tasks from at least 25 distinct accounts, at least 95 percent verified-success by the user-agreed deadline, zero hard blockers.

Issues found and resolved. (1) "Five navigation surfaces" in the G3 exit evidence was never enumerated in v1.1 — resolved as Tasks, Library, Feed, Goals, Settings in the turnkey build prompt. (2) This review's §8/D-09 (one Linux VM per acting agent) versus v1.1 §4/§11 (disposable microVMs for untrusted code only) — resolved in the turnkey build prompt by adopting D-09 as canonical per the principal's direction; revert to microVM-only scope only on explicit instruction.

1. VERDICT & BUILD STANCE

I would sign and build on: the evidence-based completion definition (§1 — a model statement is not evidence, timeouts stay unresolved until reconciled); the trust-level taxonomy (§4 — model output is a proposal, permits are one-effect, observations are not verification); the broker permit model with double-checked revocation (§9); the honest coverage ledger where every row is "designed only" and simulated adapters never count as shipped (§17); and the threat regression set (§15).

I would not sign yet: any G1 build while the calendar-provider decision (D-01) is unresolved; any model route touching user data without the eval gate (G-02); invited alpha without a named incident owner (D-05) and the legal workstream (G-07) underway.

Build stance: start G0 contract and schema work immediately, and run four spikes in parallel with G0 — (a) calendar provider capability matrix, (b) model eval harness skeleton, (c) fetch pipeline (raw HTTP vs headless render), (d) index/retrieval subsystem decision. None of these changes the security posture; they complete it.

2. DECISION LOG — resolve by the gate shown; an unresolved decision blocks its gate

D-01 Calendar provider strategy (blocks G2)

Options: (a) CalDAV-only as specified; (b) provider-native adapters (Google Calendar API v3, Microsoft Graph) plus CalDAV for iCloud/Fastmail/Nextcloud, behind one narrow Provider seam (list calendars; change-set per calendar; token exchange behind the seam); (c) CalDAV now, native later with migration. Recommendation: (b). Verified context: Google's CalDAV endpoint is a maintenance backwater with quotas re-cut in May 2026; working calendar projects integrate Google over its own REST API, not CalDAV, and treat generic CalDAV as the route to iCloud/Nextcloud only. Acceptance: capability-matrix doc recording, per server class (iCloud, Fastmail, Google, Nextcloud/Baikal), the exact outcomes of the §10 capability test (conditional PUT semantics, UID handling, attendee/iTIP behavior, test-calendar availability). If (a) is kept, the blueprint must state which real servers pass and accept that Google users get read-only.

D-02 Model processor route (blocks G0)

Name the provider(s), the account-consent UX that authorizes each route, per-route cost/latency SLOs, and the failure policy: fail closed (task → waiting(provider)) vs explicit user-visible degraded mode. "No silent transfer to another processor" is kept; add "no silent degradation either."

D-03 Workflow engine (blocks G0)

Confirm Temporal, pin the exact server version, and write the workflow-versioning strategy (how in-flight workflows survive code deploys — the blueprint asserts "tested replay" without a mechanism). Alternative on record: PG-backed durable queue; rejected only with a written reason.

D-04 Index/retrieval subsystem (blocks G0)

§12 requires purging "derived indexes/previews" and §8 requires owner/scope-filtered retrieval, but no component owns embeddings or the index. Decide: pgvector inside PostgreSQL 18 vs a separate index service. Specify purge semantics (synchronous within the delete transaction vs background with receipt line-item) and the embedding model/version pinning.

D-05 Operations ownership (blocks G2, not G4)

Name the incident owner and on-call model now. Deliverable: wrong-external-action runbook (freeze dispatch class, preserve evidence, revoke credentials, reconcile, notify, fix, narrow resume) plus a break-glass procedure (dual control, time-boxed, full audit).

D-06 Legal & compliance workstream (blocks G5)

Scope: processor DPA with flow-down of the no-training-use clause; Terms + Privacy Policy; EU AI Act Art. 50 design — agents must disclose AI nature AND the principal on whose behalf they act at key steps (authorization, reporting, validation), and synthetic text outputs (the PDF brief) need machine-readable marking per Art. 50(2), in force since 2 Aug 2026 with no transition for new systems; fetch copyright/redistribution policy (see G-07).

D-07 Fetch policy (blocks G1)

robots.txt respect, per-host rate limits, crawler user-agent identifying Kethora with an abuse contact, and a rule for paywalled/login-walled pages (unavailable unless a user-connected grant exists — no credential stuffing, no ToS evasion).

D-08 Region & DR posture (blocks G0)

Affirm: single US-East region authoritative for writes, second-zone standby, backup-restore DR (not failover). Write explicit RTO/RPO: restore <4h, ≤15min backup gap, then write-disabled reconciliation. State what "standby" can and cannot do.

D-09 Agent VM substrate (blocks G0)

Decide: cloud VMs vs microVMs (e.g., Firecracker) with VM-grade isolation; base-image pinning and supply chain (signed images, no mutable `latest`, SBOM recorded); provisioning-latency budget that fits inside the task's turn/time budget; per-agent VM cost ceiling feeding the \$16 cost ledger; VM class tiers (interactive vs background agents such as Feed/monitors). Security rules: base-image attestation; secrets never baked into images; per-task egress allow-list; audit log shipped before termination.

3. GAP REGISTER

Format per gap: Severity | Blueprint ref | Gap | Why it matters | Remediation + acceptance criteria | Gate.

G-01 BLOCKER | \$2, \$10 | CalDAV-only write strategy vs provider reality.

The \$10 capability test assumes a "dedicated user-authorized test calendar" and clean conditional-PUT semantics; real servers vary wildly (no MKCALENDAR on Google/Posteo/GMX; Google CalDAV quotas re-cut May 2026; iTIP attendee handling inconsistent). Why it matters: the entire consequential-action pipeline could be built against a protocol most users' calendars barely speak. Remediation: execute D-01; per-server-class acceptance tests (new S-tests); connection status must distinguish "writable (tested)" per server class, never a global writable flag. Gate G2.

G-02 BLOCKER | §12, §18 | No model-quality evaluation.

The suite tests plumbing, never whether the brief is good; citation faithfulness is the known failure mode of exactly this task. Remediation: golden eval set (≥ 50 tasks: brief quality, citation support judged supported/inference/disputed/missing by a held-out judge plus human spot checks); regression gate on any model/route/prompt/context-assembly change; quality dashboard tracking faithfulness and user correction rate. New tests E01–E04. Gate G1.

G-03 BLOCKER | §12 | "Support judgment" mechanism undefined.

"A reviewer or separately recorded qualitative check judges whether the excerpt actually supports a claim" — who? Remediation: define as a second-model review call with its own eval (G-02 covers it), budgeted inside the task ceiling, recorded as its own evidence entry with judge identity/version; OR define the human-in-loop variant and its latency SLA. Acceptance: every "verified factual brief" label traces to a recorded judgment event. Gate G1.

G-04 BLOCKER | §2, §16 | Ops/incident ownership punted ("operator-owned... environment configuration"; owner appears only as G4 exit evidence).

Why it matters: a system that acts on the outside world needs a human accountable before it acts, not at the production-envelope gate. Remediation: D-05; runbook drilled once on staging before G2 exit. Gate G2.

G-05 MAJOR | §16 | Budget exhaustion can interrupt a consequential effect mid-flight.

"Preserve a checkpoint, show the reason and next user choice" — but if the \$2 ceiling hits after dispatch and before read-back, the design manufactures the uncertain state §9 exists to avoid. Remediation: reserve verification/reconciliation budget up front at claim time; the cap may stop new work but never a consequential effect's read-back. New test A16: kill budget mid-calendar-write, assert read-back still executes and the task lands in needs_reconciliation or completed — never silently partial. Gate G2.

G-06 MAJOR | §13 | Feed background spend unbounded.

Monitors have cost ceilings, Ideas have quotas; Feed editions require source fetches plus per-card factual-support checks — likely the most expensive loop in the system. Remediation: per-edition cost ceiling + daily background budget; edition marked partial when the ceiling binds (never silently thinner). New coverage row C21. Gate G3.

G-07 MAJOR | §2, §14 | Legal/compliance workstream missing.

"User-facing terms" as environment config; no DPA; no AI Act transparency design; no fetch copyright policy. Remediation: D-06; approval card for calendar events discloses "the server will notify N attendees"; PDF briefs carry machine-readable AI-generation marking (Art. 50(2)); fetch policy per D-07. Gate G5 (workstream opens at G0).

G-08 MAJOR | §20 | G1 is a boil-the-ocean gate.

First user value arrives after auth, command/outbox, Temporal, model gateway, artifact store, and both clients. Remediation: add milestone M0 "first user outcome on fixtures" with a date, OR explicitly accept the runway in writing with a dated G1 target. Also strike §21's "no additional product architecture decision is required" — replace with the decision log (§2 of this plan).

G-09 MAJOR | §2, §3 | Approval-expiry UX collision.

Approvals die after 15 min; iOS push is "a hint to refresh." The most common support ticket will be "I approved but it expired." Remediation: expiring-soon nudge at 5 min remaining; one-tap re-request that re-renders the trusted card from the immutable payload (new payload version if anything changed — approval invalidated, per §9); expired approvals show what expired and why, never a dead button. New test U15. Gate G2.

G-10 MAJOR | §15 | Recovery-codes ceremony vs step-up interplay undefined.

Account reset requires "recent authenticated step-up," but the user reaching for recovery codes has lost their passkey — step-up via what? Remediation: specify the recovery ceremony (recovery code + email verification + mandatory session rotation + 24h delay on destructive actions after recovery, or equivalent); test S07 attempts reset with only a recovery code and asserts the delay/rotation. Gate G2.

G-11 MAJOR | §7 | Idempotency-key retention undefined.

Keys forever = unbounded storage; TTL = replay risk. Remediation: retain keys $\geq$ max task deadline + reconciliation window (e.g., 30 days), then tombstone; add index on (tenant_id, idempotency_key); document the replay behavior after expiry (safe: mutations revalidate revision/approval before acting). Gate G1.

G-12 MAJOR | §2 | Clock-skew bound missing for 30s executor leases / 60s dispatch permits.

Lease/fence correctness assumes bounded skew across API, broker, gateway, workers. Remediation: NTP required on all hosts; skew budget $\leq 2s$ enforced at fence validation (reject claims when skew unknown); document in runbook. Gate G1.

G-13 MAJOR | §4, §8, §12 | Retrieval/index subsystem unspecified (see D-04).

Remediation: decide and assign component ownership; acceptance: delete-source flow (J3) provably purges vectors within the stated SLA with a receipt line-item. Gate G0.

G-14 MAJOR | §3 (C16), §18 (P09) | Notification dedup/idempotency thin.

"Without double alerts" across inbox/email/push needs an idempotency story; email delivery itself can fail silently. Remediation: notification outbox with per-recipient idempotency keys; states queued → provider-accepted → device-displayed where observable (§14 already wants this for alerts — extend to all notifications); test P10: duplicate scheduler wake emits one user-visible notice. Gate G4.

G-15 MAJOR | §1, §17 | No outcome-quality metrics or user feedback loop.

The ledger tracks functional coverage, not whether users got what they asked for. Remediation: receipt-level feedback ("was this right?" one tap) feeding the eval set and the quality dashboard; correction rate per task class as a release-health metric; new row C22. Gate G3.

G-16 MAJOR | §19 | Temporal workflow versioning asserted without a mechanism ("versions of in-flight workflows remain supported or migrated with tested replay").

Remediation: D-03's versioning doc; acceptance: deploy N+1 with an in-flight approval-waiting workflow and assert it resumes correctly (fault test). Gate G0.

G-17 MAJOR | §4 | Credential-flow diagram missing.

The blueprint diagrams control flow and correctly notes it is not credential flow — but no credential-flow diagram exists. Remediation: G0 deliverable showing every credential's issuance, scope, lifetime, and revocation path (user tokens, broker signing keys, gateway-injected provider credentials, sandbox none-by-design). Any credential reachable from model context, generated code, or browser session fails review. Gate G0.

G-18 MAJOR | §8, §18 | Processor outage / model schema failure untested.

waiting(reason) includes "provider," but no test maps a dead model route or a schema-invalid response to it. Remediation: tests A17 (processor timeout mid-task → waiting(provider), resume on recovery, no partial artifact published) and A18 (schema-invalid model output → exactly one repair attempt → defined wait/failure, user-visible reason). Gate G1.

G-19 MINOR | §14 | Tombstone vs backup lifetime wording.

"Tombstones remain long enough... then expire under a documented schedule" while backups roll 30 days — after tombstone expiry, an old-backup restore can resurrect data. Remediation: tombstones outlive the oldest restorable backup, OR backups are crypto-shredded per tenant on reset. State which. Gate G4.

G-20 MINOR | §12 | PDF accessibility absent from artifact checks.

"Parse, render, contain expected sections" — for a brief product, require tagged PDF (PDF/UA) with heading structure and alt text for figures; add to format-specific checks. Gate G1.

G-21 MINOR | §2 | Archive-import limits (500 entries / 100MB / 4 levels) have no coverage row and no surface that clearly uses them.

Remediation: add row C23 tying limits to the upload/attachment path, or drop the limits. Gate G1.

G-22 MINOR | §18 | One "safely controlled real integration account" is thin for §10's server-diversity problem.

Remediation: test-account matrix per supported server class (G-01's matrix); fixture mode covers the state machine, live mode covers server quirks. Gate G2.

G-23 MINOR | §20 | G5 exit "observed cost and verified-success denominator" is vague.

Remediation: define denominator (per task cohort over the invited-alpha window) and thresholds, e.g., verified-success $\geq 95\%$ of completed tasks, zero hard-blocker events. Gate G5.

G-24 MINOR | §9, §10 | Attendee notification side effect undisclosed; recurrence undecided.

Creating an event with attendees makes the server send iTIP invites — a consequential side effect beyond the event itself. Remediation: approval card states attendee notification explicitly; v1 scope = single events only (no RRULE/VALARM) unless RRULE gets its own operation metadata and tests. Gate G2.

G-25 MINOR | §2 | Turn/replan accounting undefined.

"Twelve model turns, two substantive replans" — does a schema-repair retry count? Child-worker turns? Support-judgment calls (G-03)? Remediation: define counting rules in versioned config; UI shows turns consumed. Gate G1.

G-26 MINOR | §7 | No 429/rate-limit contract.

§15 requires rate limiting; the API section should specify the 429 shape, Retry-After, and per-operation quota headers. Gate G1.

G-27 MINOR | §14 | Per-task diagnostic capture for on-call.

"Raw diagnostics off by default" + 14-day metadata retention leaves model-quality regressions undebuggable. Remediation: sampled (e.g., 5%), consented, per-task diagnostic capture with 30-day retention, excludable per task; access-logged. Gate G4.

G-28 MINOR | §9 | Policy-change rollout unspecified.

Policy epoch is checked at claim (good), but how does a policy revision roll out? Remediation: policy changes are versioned, canaried, and never retroactively invalidate in-flight permits; runbook entry. Gate G2.

G-29 MINOR | §3, §15 | Mobile/client hardening details.

Specify: iOS keychain accessibility class for the device-bound refresh credential; Data Protection class for cached artifacts; APNs provider-auth (token, not certificates); web approval pages on a separate origin from any agent-rendered content; invite-code single-use + App Attest for the 100-account alpha. Gate G4.

G-30 MINOR | §3 (J1) | Claim-dependency graph for invalidation.

"Revision 2 invalidates affected claims" requires knowing which claims derive from which sources. Remediation: the evidence manifest (§12) doubles as the lineage index: claim → source version → artifact version; invalidation walks the graph; unaffected evidence preserved (already required — now implementable). Acceptance: J1 correction test asserts v1 claims marked stale and v2 re-verified. Gate G1.

G-31 MINOR | §13 | Monitor grant "authority expiry" renewal UX undefined.

A monitor whose write authority expires silently stops being useful. Remediation: expiring-authority notice ≥7 days ahead; renewal is a fresh grant ceremony, never auto-extended. Gate G3.

G-32 MINOR | §14 | Export portability.

"Versioned manifest with object IDs, relationships, hashes, formats and omissions" — state explicitly that v1 export is not importable (no restore-to-new-account), or scope the import work. Gate G4.

G-33 MINOR | §15 | Threat set additions.

(a) compromised model processor returning malicious structured output → control is schema validation + output allow-listing, add test S07b; (b) malicious OAuth/calendar endpoint harvesting credentials → control is capability test + URL allow-list + credential binding, add test S08; (c) approval phishing via email link → control is "approvals only in trusted UI," add negative test. Gate G2.

G-34 MINOR | §6 | Task expiry semantics.

Terminals include "expired" but nothing defines when a task expires or what happens to permits/in-flight claims at deadline_at. Remediation: at deadline, revoke unconsumed permits, cancel dispatch, reconcile in-flight effects, receipt states what expired vs completed. Test A19. Gate G1.

G-35 MINOR | §16 | Single-region affirmation (see D-08).

Also: "two replicas across two AZs" for API/broker/gateway — state the failure being survived (AZ loss, not region loss) so nobody mistakes it for DR. Gate G0.

4. SPEC DELTAS (concrete amendments to the blueprint)

4.1 New coverage-ledger rows (append to §17 table; all start "designed")

C21 Schedule Feed editions within a background cost ceiling (Feed service; tests P10, E04; iOS, web; G3).

C22 Capture receipt-level outcome feedback and correction rate (evidence/product; tests E01–E03; iOS, web; G3).

C23 Enforce archive/attachment import limits with quarantine (input/upload; tests S05, A20; iOS, web; G1).

C24 Distinguish per-server-class calendar write support (connector/Settings; tests A14x, S08; iOS, web; G2).

C25 Approval expiry with one-tap re-request from the immutable payload (broker/approval; tests U15; iOS, web; G2).

C26 Task deadline expiry revokes permits and reconciles in-flight effects (command/workflow; tests A19; iOS, web; G1).

C27 Each acting agent runs in its own Linux VM with no cross-agent network route and no ambient credentials (sandbox/infra; new test S09; G2).

4.2 New acceptance tests (append to §18)

A16 budget-exhaustion during calendar write → read-back still executes; terminal state honest. A17 processor timeout → waiting(provider) → resume, no partial publish. A18 schema-invalid model output → one repair → defined wait/failure with user-visible reason. A19 deadline expiry → permits revoked, in-flight reconciled, receipt itemized. A20 hostile archive (traversal, bomb, symlink, executable prompt) → quarantined, no effect. E01–E04 model-quality eval suite (faithfulness, citation support grading, regression on route/prompt change, quality dashboard populated). P10 duplicate scheduler wake → one user-visible notice. P11 monitor authority-expiry notice and non-auto-renewal. S07 recovery-code-only reset → step-up delay/rotation enforced. S08 malicious calendar endpoint → connection refused, no credential stored. U15 expired approval → re-request flow from immutable payload. U16 large-text/screen-reader approval path end to end. M06 export-then-reset: manifest hash verifies; no import path implied. S09 a compromised agent VM attempts to reach another agent's VM, the control plane outside the broker/gateway APIs, and exfiltrate credentials — all attempts fail and are logged; VM snapshot is captured to the evidence store on termination.

4.3 Section amendments (replacement text)

§2, "First external write" row: append "Provider strategy per decision D-01; write support is per server class, never global. v1 event scope: single events only (no RRULE/VALARM) pending their own operation metadata."

§2, "Limits" row: append "Turn/replan counting rules are versioned configuration; the client shows turns consumed."

§9, approval card paragraph: append "The card states attendee-notification consequences explicitly. Expiry triggers the re-request flow (C25); a material payload change invalidates approval."

§10, production creation: "Derive the resource name deterministically from the logical effect key via a KDF so retries map to the same resource; normalize event times to UTC with the original IANA zone preserved in a property; store the byte digest before dispatch."

§12, artifact publication: append "PDF artifacts must be tagged (PDF/UA): heading structure, reading order, alt text for figures."

§14, retention paragraph: replace the tombstone sentence with "Deletion tombstones outlive the oldest restorable backup; alternatively, tenant backups are crypto-shredded on reset. The chosen mechanism is documented and tested."

§14, export paragraph: append "v1 export is not importable; no restore-to-new-account is implied."

§16, cost ledger: append "Verification and reconciliation of a consequential effect are reserved at claim time and exempt from the task ceiling."

§16, production paragraph: append "Two-AZ deployment survives AZ loss, not region loss; region DR is backup-restore per D-08."

§21, final paragraph: replace with "The next action is G0 (repository, migrations, typed contracts, operation registry, fixtures, invariant tests) plus the four parallel spikes (D-01 calendar matrix, eval harness, fetch pipeline, D-04 index decision) and the G0 deliverables (credential-flow diagram, workflow-versioning doc, decision log). No user-facing build starts until D-01–D-04 are recorded."

5. REVISED GATE EXIT CRITERIA (additions only; existing criteria stand)

G0 adds: decision log D-01–D-04 recorded; D-09 recorded; credential-flow diagram reviewed; Temporal version pinned + versioning doc; fetch policy (D-07) written; calendar capability-matrix spike executed (results may be "Google needs native adapter" — that is a finding, not a failure).

G1 adds: eval harness running with baseline scores (E01–E04); support-judgment mechanism defined and recorded (G-03); idempotency retention + skew bound implemented; A16–A20 green.

G2 adds: incident owner named + wrong-action runbook drilled on staging; calendar provider matrix green per server class (or explicit read-only labeling); S07/S08, U15 green; recovery ceremony specified; first VM-provisioned worker runs on staging; S09 green.

G3 adds: Feed cost ceiling enforced (C21); feedback capture live (C22); P10/P11 green.

G4 adds: tombstone/backup mechanism tested; notification dedup proven (P10 across channels); diagnostic capture policy live; client hardening list (G-29) complete.

G5 adds: legal workstream complete (terms, privacy, DPA, Art. 50 disclosures + PDF marking); load test passed with published cohort/region/dependency parameters; verified-success denominator defined and met; zero hard-blocker events in the alpha window.

6. BUILD ORDER — FIRST FOUR WEEKS (as the builder)

Week 1: repo skeleton + G0 docs (decision log, credential-flow diagram, Temporal versioning doc); calendar capability-matrix spike against iCloud/Fastmail/Google/Nextcloud; fetch-pipeline spike (raw vs headless render) with robots/rate-limit policy draft.

Week 2: command/outbox + task state machine + API auth (passkey-first) + idempotency; model gateway with InferRequest/InferResult, schema validation, deterministic test mode, and the eval harness skeleton.

Week 3: broker + one-effect permits + trusted approval UI (separate origin/sheet) + revocation; calendar adapter against the matrix winner(s); reconciler with the uncertain-effect path; budget reservation including the verification carve-out.

Week 4: artifact pipeline (PDF/UA, evidence manifest as lineage index) + J1 thin slice end-to-end on fixtures across iOS simulator and web; correction/invalidation walk (G-30); first eval baseline scores recorded.

7. SCOPE GUARDS (non-goals restated so they stay non-goals)

No agent-initiated purchases or financial commitments; no multi-region failover; no importable export; no recurring calendar events or alarms in v1; no silent processor transfer or silent degradation; no simulated backend behind any visible feature; no infinite background-task chains; no auto-renewal of monitor write authority; no training use of user content by this product's pipeline or its processors (contractual flow-down).

8. AGENT COMPUTE LAYER: ONE LINUX VM PER AGENT

Intention: every agent — the persistent personal agent and each spawned worker or subagent that needs to act — gets its own Linux VM: its own computer with a dedicated filesystem, process space, network identity, and credential scope. Not a shared sandbox pool with soft isolation; a real machine boundary per agent.

Why a machine boundary, not just a sandbox

- Strongest isolation for generated code, browser automation, and tool execution (extends the blueprint's §11 from "sandbox" to a full VM).
- Blast-radius containment: a compromised or buggy agent cannot touch another agent's state, credentials, or in-flight work.
- Per-agent audit trail and cost attribution — each VM's activity and spend are attributable to exactly one agent.
- The broker's one-effect permits map cleanly onto machine-scoped capabilities: a VM holds only what its agent is permitted to use.
- Agents can install tools, keep working state, and run long-lived processes without cross-agent interference.

Relationship to the existing blueprint

- Each VM is provisioned with zero credentials. It receives only broker-issued, scoped, time-boxed credentials for its task — never a user's long-lived tokens, never another agent's credentials.
- A VM has no network route to other agents' VMs or to the control plane except the broker/gateway APIs. All egress goes through the fetch proxy under the fetch policy (D-07). No shared kernel-level trust between agents.
- VM-local audit logs are shipped to the evidence store before termination, so the evidence manifest (§12) covers agent-local actions too.

Lifecycle: provision on agent spawn; snapshot on task completion for evidence; terminate after the retention window; idle VMs suspend rather than run and bill.

9. APPENDIX — sources consulted for provider/legal grounding

- Google CalDAV status: <https://github.com/xiovv/calich/blob/HEAD/docs/adr/0050-providers-integrate-over-their-own-apis-not-caldav.md> ("Google's CalDAV endpoint is a maintenance backwater... It is supported, not invested in." Quotas re-cut May 2026.)
- CalDAV server quirks survey: <https://github.com/foundry376/mailespring/blob/HEAD/plans/caldav-provider-quirks/06-mkcalendar.md>
- EU AI Act Art. 50 (in force 2 Aug 2026): <https://www.mondaq.com/new-technology/1843358/eu-ai-act-article-50> and <https://www.faegredrinker.com/en/insights/publications/2026/7/eu-ai-act-commission-confirms-transparency-code-of-practice-as-adequate-and-publishes-final-version-of-its-guidelines-on-transparency-obligations?format=pdf> (agents must disclose AI nature + principal; synthetic text needs machine-readable marking; no transition for systems placed on market after 2 Aug 2026).